# 🏢 Lab 2 – NordActive Holding
## Active Directory Yetkilendirme ve Erişim Denetimi Deneyimi
## Senaryo
Bir bilgi sistemleri denetçisi olarak NordActive Holding'in kurumsal Active Directory altyapısının güvenlik ve erişim yönetimi denetimini gerçekleştirmek üzere görevlendirildiniz.
Denetim planlama görüşmeleri sırasında BT altyapı ekipleri ve sistem sahipleri aşağıdaki bilgileri paylaşmıştır:
● Active Directory ortamı uzun yıllardır kullanılmaktadır.
● Kullanıcı hesapları İnsan Kaynakları süreçleri ile yönetilmektedir.
● Ayrılan çalışanların hesapları zamanında kapatılmaktadır.
● Ayrıcalıklı hesaplar sıkı şekilde kontrol edilmektedir.
● Domain Admin yetkileri yalnızca ihtiyaç duyan kişilerde bulunmaktadır.
● Servis hesapları güvenli şekilde yönetilmektedir.
● Grup üyelikleri düzenli olarak gözden geçirilmektedir.
● GPO yapılandırmaları sektör standartlarına uygundur.
● Parola politikaları güçlüdür.
● Ayrıcalık yükseltme riskleri bulunmamaktadır.
● Yetki matrisi güncel tutulmaktadır.
● Active Directory ortamında herhangi bir kritik güvenlik riski bulunmamaktadır.
Kısacası sistem sahiplerinin beyanına göre Active Directory ortamı güvenli şekilde yönetilmektedir.
Ancak bir denetçi olarak yalnızca beyanlara güvenmek yerine kanıt toplamanız, teknik doğrulamalar yapmanız ve riskleri bağımsız şekilde değerlendirmeniz beklenmektedir.
Bu amaçla BT ekibinden yalnızca okuma yetkisine sahip bir Domain User hesabı talep ettiniz. Ekip gerekli erişimleri sağlayarak inceleme yapmanıza izin verdi.
Göreviniz; Active Directory ortamını teknik olarak incelemek, erişim yönetimi risklerini belirlemek, bulguları kanıtlarıyla desteklemek ve profesyonel bir denetim raporu hazırlamaktır.

## Erişim Bilgileri
RDP istemcisi kullanarak aşağıdaki sunucuya bağlanabilirsiniz.
Sunucu Adresi:
**dc01.nordactive.local**
Kullanıcı:
**audituser**
Etki Alanı:
**NORDACTIVE**
🔑 Erişim bilgilerini support@siberkobi.co adresinden talep edebilirsiniz.
Daha önce aldıysanız bu adımı atlayabilirsiniz.

## Beklentiler
Denetim sırasında aşağıdaki başlıkları risk bakış açısıyla değerlendirmeniz beklenmektedir:
● Kullanıcı yaşam döngüsü yönetimi

● Ayrıcalıklı hesap yönetimi
● Domain Admin yetkileri
● Grup üyelikleri
● Service Account yönetimi
● Parola politikaları
● Hesap kilitleme kontrolleri
● Group Policy (GPO) yapılandırmaları
● Yetki matrisi kontrolleri
● Eski ve kullanılmayan hesaplar
● Delegated Admin yetkileri
● Tiering ve ayrıcalık ayrıştırması
● Kerberos ve kimlik doğrulama güvenliği
● Active Directory hardening kontrolleri
Amaç komut ezberlemek değil, bir denetçi gibi düşünerek riskleri tespit etmek ve bunları kanıtlarla destekleyebilmektir.

## Teslimat

Çalışma sonunda yalnızca bu Active Directory ortamına özel kısa bir denetim raporu hazırlayın.
Raporda aşağıdaki bölümler bulunmalıdır:
● Yönetici Özeti
● Denetim Kapsamı
● Yapılan Testler
● Tespit Edilen Bulgular
● Risk Değerlendirmesi
● Öneriler
Hazırladığınız raporu:
📧 support@siberkobi.co
veya
👤 Volkan Güler
ile paylaşabilirsiniz.

## Önemli Not

Bu laboratuvar çalışması eğitim amaçlı hazırlanmıştır.
Lab ortamında yer alan kullanıcılar, gruplar, organizasyon birimleri (OU), GPO'lar, servis hesapları ve sistem yapılandırmaları tamamen eğitim amacıyla oluşturulmuştur.
Çalışma sırasında karşılaşacağınız hiçbir bilgi, kullanıcı veya yapılandırma gerçek bir kurum ya da üretim ortamını temsil etmemektedir.
Amaç; katılımcıların gerçek hayatta karşılaşabilecekleri Active Directory denetimlerini kontrollü bir ortamda deneyimlemeleri ve risk odaklı denetim yaklaşımını uygulamalı olarak öğrenmeleridir.

**********

## Active Directory Security Audit – Denetçi Rehberi

## 1. Domain Bilgileri

```
Get-ADDomain

Get-ADForest

Get-ADDomainController -Filter *
```

Amaç:
● Domain yapısını anlamak
● Domain Controller'ları tespit etmek
● Forest mimarisini incelemek

## 2. Kullanıcı Hesapları

```
Get-ADUser -Filter *

Get-ADUser -Filter * -Properties Enabled,LastLogonDate

Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00
```

Amaç:
● Eski çalışan hesapları
● Kullanılmayan hesaplar
● Riskli kullanıcılar

## 3. Domain Admin Yetkileri

```
Get-ADGroupMember "Domain Admins"

Get-ADGroupMember "Enterprise Admins"

Get-ADGroupMember "Administrators"
```

Amaç:
● Aşırı yetkilendirme
● Gereksiz admin hesapları
● SoD ihlalleri

## 4. Grup Üyelikleri

```
Get-ADGroup -Filter *

Get-ADPrincipalGroupMembership username
```

Amaç:
● Yetki birikmesi

● Rol bazlı erişim eksiklikleri
● Gereksiz grup üyelikleri

## 5. Service Account İncelemesi

```
Get-ADUser -Filter {ServicePrincipalName -like "*"}

Get-ADUser svc_backup -Properties *
```

Amaç:
● Shared account kullanımı
● Eski servis hesapları
● Yüksek ayrıcalıklı servis hesapları

## 6. Parola Politikaları

```
Get-ADDefaultDomainPasswordPolicy
```

Amaç:
● Minimum parola uzunluğu
● Hesap kilitleme
● Parola geçmişi

## 7. Group Policy (GPO) İncelemesi

```
Get-GPO -All

Get-GPOReport -All -ReportType Html
```

Amaç:
● Güvenlik ayarları
● Hardening eksiklikleri
● Riskli GPO'lar

## 8. Yetkilendirme Analizi

```
Get-ADOrganizationalUnit -Filter *

Get-Acl "AD:\OU=Users,DC=nordactive,DC=local"
```

Amaç:
● Delegated Admin yetkileri
● Yetki devri kontrolleri
● Ayrıcalık yükseltme riskleri

## 9. Hesap Kilitleme ve MFA

```
Get-ADUser -Filter * -Properties LockedOut

Search-ADAccount -LockedOut
```

Amaç:
● Kilitlenen hesaplar
● Brute force göstergeleri
● MFA eksiklikleri

## 10. Eski ve Riskli Hesaplar

```
Search-ADAccount -PasswordNeverExpires

Search-ADAccount -AccountDisabled

Search-ADAccount -AccountInactive
```

Amaç:
● Password Never Expires hesapları
● Yetim hesaplar
● Güvenlik açıkları

## 11. Kerberos ve SPN İncelemesi

```
setspn -Q */*

Get-ADUser -Filter {ServicePrincipalName -like "*"}
```

Amaç:
● Kerberoasting riskleri
● SPN yapılandırmaları
● Yetki yükseltme senaryoları

## 12. Active Directory Hardening

```
Get-ADComputer -Filter *

Get-ADComputer -Filter * -Properties OperatingSystem
```

Amaç:
● Eski işletim sistemleri
● Destek dışı sistemler
● Hardening eksiklikleri

## 13. Kritik Güvenlik Grupları

```
Get-ADGroupMember "Backup Operators"

Get-ADGroupMember "Account Operators"

Get-ADGroupMember "Server Operators"
```

Amaç:
- Gizli ayrıcalıklar
- Yetki yükseltme yolları
- Kritik erişim riskleri